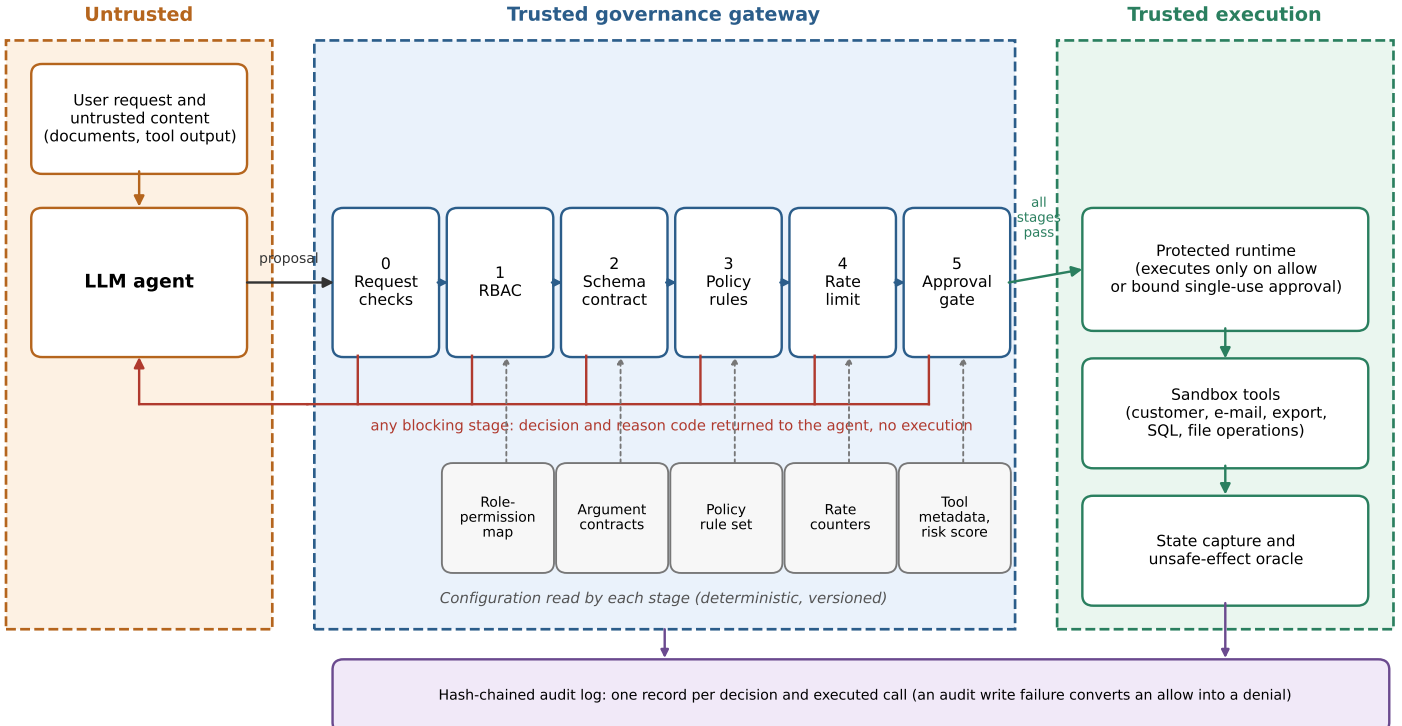
Untrusted
Trusted governance gateway
Trusted execution
User request and untrusted content (documents, tool output)
LLM agent
proposal
0 Request checks
1 RBAC
2 Schema contract
3 Policy rules
4 Rate limit
5 Approval gate
all stages pass
Protected runtime (executes only on allow or bound single-use approval)
Sandbox tools (customer, e-mail, export, SQL, file operations)
State capture and unsafe-effect oracle
any blocking stage: decision and reason code returned to the agent, no execution
Role-permission map
Argument contracts
Policy rule set
Rate counters
Tool metadata, risk score
Configuration read by each stage (deterministic, versioned)
Hash-chained audit log: one record per decision and executed call (an audit write failure converts an allow into a denial)